Day 4: Footprinting & Reconnaissance (Passive)

Table of Contents

1. Introduction
2. Objective of the Day
3. The Reconnaissance Phase
   a) Passive vs. Active Recon
   b) What are we looking for?
4. Tools & Techniques Used
5. What I Did Today
6. What I Learned (Key Outcomes)
7. Hands-on Examples & Intelligence Gathering

1. Introduction

In the world of ethical hacking, "Footprinting" is the first step of an attack. It is the process of gathering as much information as possible about a target network to identify potential entry points. Today, we focused on **Passive Reconnaissance**, which means collecting data without ever interacting directly with the target's servers.

2. Objective of the Day

The goal of Day 4 is to learn how to use publicly available resources (OSINT - Open Source Intelligence) to map out a target's digital footprint, including domain ownership, IP ranges, and employee information.

3. The Reconnaissance Phase

A. Passive vs. Active Recon

- **Passive Recon:** You gather info from 3rd party sources (Google, LinkedIn, WHOIS). The target has **no way** of knowing you are looking at them.
- **Active Recon:** You interact with the target (Port scanning, pinging). This is faster but can be logged by firewalls and security systems.

B. What are we looking for?

- **Domain Details:** Who owns the site? When does it expire?
- **IP Addresses:** What is the server's actual location?
- **Email Addresses:** Useful for future social engineering or credential testing.
- **Subdomains:** Often, subdomains like `dev.example.com` or `test.example.com` are less secure than the main site.

4. Tools & Techniques Used

1. **WHOIS:** A database that contains the registration information of domain names.
2. **NSLookup / Dig:** Used to query DNS servers to find IP addresses and mail server records.
3. **TheHarvester:** A powerful Kali tool that scrapes search engines and social media for emails, subdomains, and hostnames.
4. **Shodan.io:** Known as the "Search Engine for the Internet of Things (IoT)." It finds connected devices like webcams, industrial routers, and servers.

5. What I Did Today

1. **Domain Research:** I performed a `whois` lookup on a public domain to identify the registrar and name servers.
2. **Email Harvesting:** I used `theHarvester` to see how much public information is available about a sample organization.
3. **DNS Enumeration:** I used `nslookup` to find the Mail Exchange (MX) records of a target, showing where their emails are processed.
4. **Google Dorking:** I practiced using advanced search operators (like `site:`, `filetype:pdf`, `intitle:index of`) to find exposed sensitive files on the internet.

6. What I Learned

- **Information Leakage:** It is surprising how much information a company "leaks" just by existing online.
- **The Importance of Privacy:** I learned why companies use "WHOIS Protection" to hide their personal contact details from hackers.
- **OSINT Power:** You can find almost everything about a target without ever sending a single packet to their server.

Key Takeaway for Newbies:

"Reconnaissance is 70% of a successful hack. The more you know about your target, the easier it is to find a way in."

7. Hands-on Examples & Intelligence Gathering

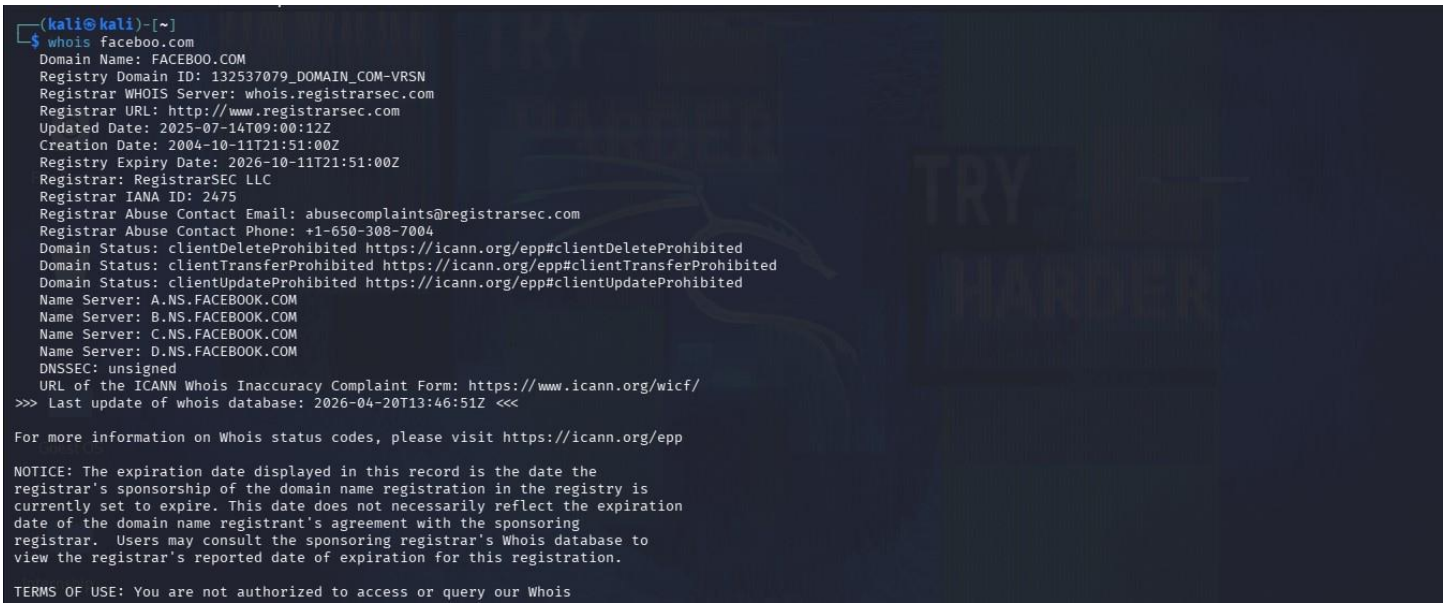
- **Task:** Use the terminal to find the owner of a domain and its IP address.

Execution:

1. `whois google.com` (To see registration details).
2. `nslookup google.com` (To see the IP addresses).
3. `theHarvester -d example.com -b crtsh -l 50` (To search for emails).

    - To use this tool, we will need API keys, which we will save in this location.
        - `"nano etc/theHarvester/api-keys.yaml"`

Screenshot 1: Terminal showing the output of a `whois` command.



```
┌──(kali㉿kali)-[~]
└─$ whois faceboo.com
   Domain Name: FACEBOO.COM
   Registry Domain ID: 132537079_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.registrarsec.com
   Registrar URL: http://www.registrarsec.com
   Updated Date: 2025-07-14T09:00:12Z
   Creation Date: 2004-10-11T21:51:00Z
   Registry Expiry Date: 2026-10-11T21:51:00Z
   Registrar: RegistrarSEC LLC
   Registrar IANA ID: 2475
   Registrar Abuse Contact Email: abusecomplaints@registrarsec.com
   Registrar Abuse Contact Phone: +1-650-308-7004
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: A.NS.FACEBOOK.COM
   Name Server: B.NS.FACEBOOK.COM
   Name Server: C.NS.FACEBOOK.COM
   Name Server: D.NS.FACEBOOK.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-04-20T13:46:51Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar.  Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
```

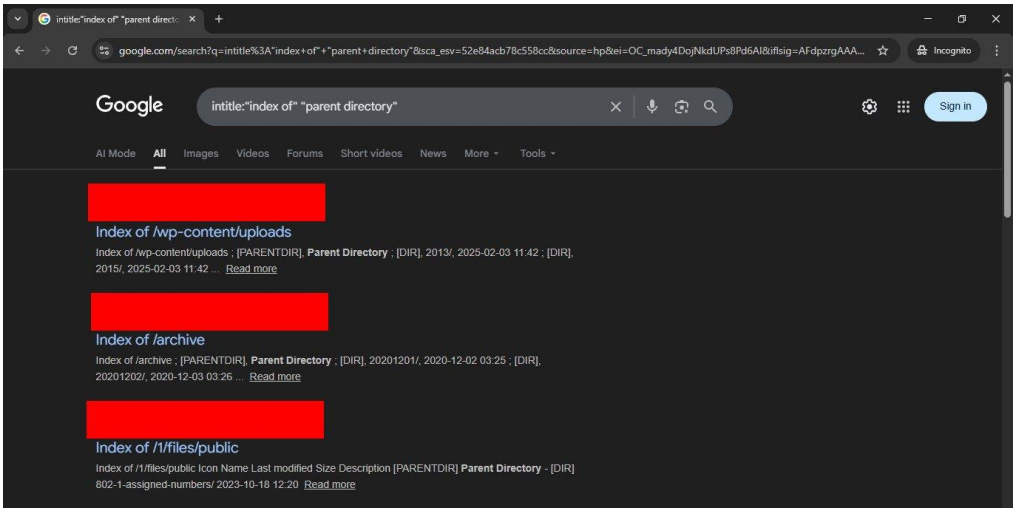
Screenshot 2: Results of an `nslookup` query showing "Non-authoritative answer."

```
┌──(kali㉿kali)-[~]
└─$ nslookup facebook.com
Server:
Address:

Non-authoritative answer:
Name:   facebook.com
Address: 57.144.148.1
Name:   facebook.com
Address: 2a03:2880:f34a:1:face:b00c:0:25de


┌──(kali㉿kali)-[~]
└─$
```

Screenshot 3: A "Google Dork" search result (e.g., searching for `filetype:log` for a specific site).



Date: Saturday, April 11, 2026 **Daniyal Shahid**